

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Target: DVWA (Damn Vulnerable Web Application) | Scope: localhost

Report Date:	May 31, 2026
Prepared By:	Ansh Kamlesh Kuril
Scan Engine:	Tenable Nessus Essentials v10.x
Policy Used:	Basic Network Scan
Severity Base:	CVSS v3.0
Scan Duration:	19 minutes (03:45 – 04:04)
Total Findings:	79 Vulnerabilities 4 Critical/High
Classification:	CONFIDENTIAL



01. EXECUTIVE SUMMARY

This Vulnerability Assessment and Penetration Testing (VAPT) report documents findings from an authenticated Nessus scan conducted against DVWA (Damn Vulnerable Web Application) hosted on **localhost** within an isolated lab environment. The assessment was performed using Tenable Nessus Essentials under a **Basic Network Scan** policy with CVSS v3.0 as the severity baseline.

The scan identified **79 total findings** across the target host. While no Critical or High severity findings were detected in isolation, three Medium-severity vulnerabilities were confirmed, alongside one actionable remediation (ImageMagick) spanning 6 plugin detections. The overwhelming majority of findings are informational, reflecting the system's exposed attack surface and software inventory.

Metric	Value
Target Host	localhost (127.0.0.1)
Authentication	Passed (credentialed scan)
Total Vulnerabilities	79
Critical / High	0 / 0
Medium	3
Low	1 (inferred from host bar)
Informational	~75
Actionable Remediations	1 (ImageMagick upgrade)
Scan Duration	19 minutes

02. SCOPE & METHODOLOGY

2.1 Engagement Scope

Parameter	Details
Target Application	DVWA — Damn Vulnerable Web Application
Target Host	localhost / 127.0.0.1
Environment	Isolated lab VM (Kali Linux host)
Scan Tool	Tenable Nessus Essentials v10.x
Scan Policy	Basic Network Scan
Credentials Used	Yes — authenticated scan (Auth: Pass)
Severity Framework	CVSS v3.0
Scan Date	May 31, 2026
Start / End	03:45 AM – 04:04 AM

Duration	19 minutes
----------	------------

2.2 Testing Methodology

The assessment followed a structured approach aligned with industry-standard frameworks including **OWASP Top 10** and **PTES (Penetration Testing Execution Standard)**. The methodology comprised the following phases:

Phase 1 — Reconnaissance	Service enumeration, OS fingerprinting, open port discovery via Nessus plugin engine.
Phase 2 — Vulnerability Scanning	Authenticated credentialed scan enabling deep plugin execution across installed packages, web server configs, SSL/TLS, and application layers.
Phase 3 — Vulnerability Analysis	Findings triaged by CVSS v3.0 score, categorized by family (CGI Abuses, Web Servers, Databases, General, Misc.), and mapped to remediation actions.
Phase 4 — Reporting	Structured report compiled with technical findings, risk ratings, business impact, and prioritized remediation guidance.

03. VULNERABILITY SUMMARY

3.1 Severity Distribution

Severity	Count	CVSS Range	Risk Level
Critical	0	9.0 – 10.0	Immediate action required
High	0	7.0 – 8.9	Urgent remediation
Medium	3	4.0 – 6.9	Remediate within 30 days
Low	1	0.1 – 3.9	Remediate within 90 days
Info	75	N/A	Review & monitor
TOTAL	79	—	—

3.2 Vulnerability Families Detected

Family	Findings	Notes
CGI Abuses	5+	Browsable dirs, backup disclosure, clickjacking
Web Servers	10+	HTTP issues, Apache, clickjacking, web mirroring
General	10+	SSH, SSL/TLS, STS, hostname, post-quantum
Misc.	15+	ImageMagick, Python, PHP, Ruby, Docker, Vim
Databases	4+	MariaDB, PostgreSQL, SQLite
Service Detection	6+	TLS 1.2, Docker, container, Nessus
Settings	3+	Credentials status, PATH vars, SW discovery
Artificial Intel.	2	AI/LLM Software Report, HDF5 detection
Port Scanners	3	Netstat portscanner (SSH)

04. DETAILED FINDINGS

F-001 ImageMagick < 6.9.13-44 / 7.x < 7.1.2-19 — Multiple Vulnerabilities				MIXED (Medium/High sub-CVEs)
CVSS: 5.3 – 7.8 (varies per CVE)		Family: Misc.	Plugin Hits: 6	Host: localhost
Description	Multiple vulnerabilities exist in ImageMagick versions prior to 6.9.13-44 and 7.x prior to 7.1.2-19. These include heap buffer overflows, out-of-bounds reads, and improper input validation that could allow an attacker to cause a denial of service or potentially execute arbitrary code by tricking a user or application into processing a specially crafted image file.			
Business Impact	An attacker supplying malicious image files to any web application using ImageMagick for processing (e.g., upload functionality in DVWA) could achieve Remote Code Execution (RCE) or crash the service. DVWA specifically exercises file upload flows that interact with image processing libraries.			
Remediation	Upgrade ImageMagick to version 6.9.13-44 / 7.1.2-19 or later.			
Fix Command	sudo apt update && sudo apt install --only-upgrade imagemagick			
References	CVE-2023-34151 CVE-2023-39978 CVE-2024-28229			

F-002 Browseable Web Directories				MEDIUM
CVSS: 5.3		Family: CGI Abuses	Plugin Hits: 1	Host: localhost
Description	The web server is configured to allow directory listing on one or more paths. When a directory lacks an index file, the server returns a listing of all files within that directory. This is detected via HTTP GET requests to directory paths.			
Business Impact	Directory browsing exposes the application's file structure, source code fragments, backup files, configuration files, and upload paths. This constitutes an information disclosure vulnerability that significantly aids an attacker in reconnaissance and subsequent exploitation.			
Remediation	Disable directory listing in Apache configuration. In /etc/apache2/apache2.conf or .htaccess, ensure Options -Indexes is set.			
Fix Command	echo "Options -Indexes" >> /var/www/html/.htaccess			
References	CWE-548 OWASP A05:2021 Security Misconfiguration			

F-003 Backup Files Disclosure				MEDIUM
CVSS: 5.0		Family: CGI Abuses	Plugin Hits: 1	Host: localhost
Description	The Nessus scanner detected backup or temporary files accessible via the web server. Common backup file extensions (.bak, .old, ~, .orig, .copy) were found in web-accessible directories, potentially exposing source code or configuration data.			
Business Impact	Exposed backup files may contain plaintext credentials, database connection strings, API keys, or sensitive business logic. Attackers can use this to achieve privilege escalation or lateral movement within the application.			
Remediation	Remove all backup and temporary files from the web root. Implement a file audit process to prevent accidental exposure during deployments.			
Fix Command	find /var/www/html -name "*.bak" -o -name "*.old" -o -name "*"~" xargs rm -f			

References	CWE-530 OWASP A05:2021		
------------	--------------------------	--	--

F-004 Web Application Potentially Vulnerable to Clickjacking			MEDIUM
CVSS: 4.3	Family: Web Servers	Plugin Hits: 1	Host: localhost
Description	The web application does not set the X-Frame-Options HTTP response header (or an equivalent Content-Security-Policy frame-ancestors directive). This allows the page to be embedded in iframes on external sites.		
Business Impact	An attacker can overlay transparent iframes over a legitimate-looking page to trick authenticated users into performing unintended actions (UI redressing / clickjacking). In DVWA context, this could be exploited to trigger CSRF actions or credential theft.		
Remediation	Add X-Frame-Options: DENY or SAMEORIGIN header to all HTTP responses. Alternatively, use Content-Security-Policy: frame-ancestors 'none'.		
Fix Command	Header always append X-Frame-Options SAMEORIGIN # in Apache config		
References	CWE-1021 OWASP A05:2021 CVE-2002-1366		

F-005 Remote Services Not Using Post-Quantum Ciphers			INFO
CVSS: N/A	Family: General	Plugin Hits: 1	Host: localhost
Description	Nessus detected that SSH and other remote services are not configured to use post-quantum cryptographic algorithms (e.g., CRYSTALS-Kyber, ML-KEM). This is flagged as a forward-looking informational finding related to quantum computing threats (Harvest Now, Decrypt Later — HNDL attacks).		
Business Impact	While not an immediate threat, adversaries practicing HNDL attacks may store encrypted traffic today for decryption once quantum computers become practical. Long-lived sensitive data is at elevated risk.		
Remediation	Monitor NIST PQC standard adoption (FIPS 203/204/205). Plan migration to hybrid key exchange (e.g., X25519Kyber768) in SSH and TLS configurations as OpenSSH and OpenSSL support matures.		
Fix Command	# Monitor: https://csrc.nist.gov/projects/post-quantum-cryptography		
References	NIST FIPS 203 NIST FIPS 204 Shor's Algorithm		

F-006 Web Application Cookies Not Marked HttpOnly / Secure			INFO
CVSS: N/A	Family: Web Servers	Plugin Hits: 2	Host: localhost
Description	Session cookies set by the DVWA application lack the HttpOnly and Secure flags. HttpOnly prevents JavaScript access to cookies; Secure ensures cookies are only transmitted over HTTPS. Both are absent on session tokens.		
Business Impact	Absence of HttpOnly enables cross-site scripting (XSS) attacks to steal session cookies via document.cookie. Absence of Secure flag allows cookie transmission over HTTP, enabling interception via man-in-the-middle attacks.		
Remediation	Set HttpOnly and Secure flags on all session cookies. In PHP: session_set_cookie_params(['httponly'=>true,'secure'=>true]).		
Fix Command	# php.ini: session.cookie_httponly = 1 session.cookie_secure = 1		
References	CWE-1004 CWE-614 OWASP A02:2021		

05. INFORMATIONAL FINDINGS OVERVIEW

The following informational findings do not represent exploitable vulnerabilities but provide valuable context about the system's software inventory and configuration posture. Each represents potential lateral attack surface if combined with other weaknesses.

Finding	Family	Notes
SSH Multiple Issues	General	Key exchange algos, cipher suites
HTTP Multiple Issues	Web Servers / CGI	Methods, headers, redirect chains
Apache HTTP Server Multi-Issues	Web Servers	Version disclosure, config issues
SSL/TLS Multiple Issues	General	Cipher strength, version support
Docker Multiple Issues	Misc. / Svc Det.	Container exposure, socket access
MariaDB Client/Server Installed	Databases	Version & credential exposure risk
PostgreSQL Client/Server	Databases	Service running, version info
OpenJDK Java Detection	General	Java runtime version inventory
PHP Scripting Language	Misc.	PHP version disclosure
Python Installed Packages	Misc.	Python env inventory
Ruby / Ruby Gems	Misc.	Runtime and gem inventory
AI/LLM Software Report	Artif. Intel.	AI tooling detected on host
TLS Version 1.2 Detection	Svc Detection	TLS 1.2 still active; plan 1.3 only
Web App Sitemap	Web Servers	Sitemap exposes URL structure
Web Server Office File Inv.	CGI Abuses	Office files on web server found
Strict Transport Security	Svc Detection	HSTS header presence checked
Containerd Installed	Svc Detection	Container runtime on host
Shor's Harvest Now Decrypt Later	General	Post-quantum risk advisory
Device Hostname / Type	General	Host fingerprinting data
Ethernet MAC Addresses	General	NIC-level fingerprinting

06. REMEDIATION ROADMAP

The following prioritized remediation plan is organized by severity and effort level. Actions should be executed in priority order within each timeframe.

Priorit y	Finding	Action	Effort	Timeline
P1	ImageMagick CVEs	Upgrade package via apt	Low	Immediate
P2	Directory Listing	Set Options -Indexes	Low	< 24 hrs
P3	Backup File Exposure	Remove .bak/.old files	Low	< 24 hrs
P4	Clickjacking (X-Frame)	Add X-Frame-Options hdr	Low	< 48 hrs
P5	Cookie Flags Missing	Set HttpOnly + Secure	Low	< 1 week
P6	TLS 1.2 Active	Disable TLS 1.2 configs	Medium	< 30 days
P7	SSH Cipher Hardening	Update sshd_config	Medium	< 30 days
P8	Post-Quantum Prep	Plan PQC migration	High	Strategic

07. RISK MATRIX & ATTACK SURFACE

The following table maps detected components to potential attack vectors, providing a holistic view of the target's attack surface beyond raw CVSS scores.

Component	Attack Vector	Potential Impact	Risk
ImageMagick	Malicious image upload	RCE / DoS	HIGH
Apache HTTPD	Exposed directories	Info disclosure / pivot	MEDIUM
MariaDB	Weak credentials / SQLi	Data exfiltration	MEDIUM
PHP Runtime	Code injection via DVWA	RCE / Shell	HIGH
Docker	Socket exposure	Container escape	MEDIUM
SSH Service	Weak cipher / brute force	Remote access	MEDIUM
Session Cookies	XSS + missing flags	Session hijack	MEDIUM
TLS 1.2	Cipher downgrade	Traffic interception	LOW
Python/Ruby	Dep chain attack	Supply chain risk	LOW

08. CONCLUSION & ANALYST NOTES

The DVWA scan reveals a system with a **manageable but meaningful attack surface**. The absence of Critical and High standalone CVEs is partially offset by the presence of an outdated ImageMagick installation whose sub-CVEs reach High severity, and a cluster of Medium misconfigurations that, when chained, could enable an attacker to achieve significant impact.

Key Observations:

- The ImageMagick finding (6 plugin hits) is the highest-priority remediation — a single apt upgrade resolves it entirely.
- Three Medium web misconfigurations (directory listing, backup exposure, clickjacking) are trivially exploitable and require configuration-only fixes with no downtime.
- Cookie security gaps (HttpOnly/Secure) directly enable XSS-based session hijacking which is DVWA's primary intended attack scenario.
- The informational findings reveal a broad software stack (Python, PHP, Ruby, Java, Docker, MariaDB, PostgreSQL) — each an entry point if misconfigured or outdated.
- Post-quantum readiness is flagged proactively; no immediate action required but a migration roadmap should be developed.
- Authentication was successful (credentialed scan) — the scan coverage is thorough and represents a realistic internal attacker perspective.

Overall Risk Rating: MEDIUM — Immediate remediation of ImageMagick and web misconfigurations is recommended. The system should not be exposed to public networks in its current state.

8.1 Analyst Declaration

This report was prepared by **Ansh Kamlesh Kuril**, a cybersecurity practitioner with active experience in Red Team operations, vulnerability assessment, and penetration testing. The assessment was conducted solely for educational and portfolio purposes in an isolated, personally-owned lab environment. No production systems were targeted. All findings and recommendations reflect professional judgment based on industry standards including OWASP, NIST, and CVSS v3.0 frameworks.

Ansh Kamlesh Kuril	Penetration Tester / Red Team Analyst	May 31, 2026